Path Traversal WAF Bypass Vulnerability Report

Expert track, redacted for publication. Vulnerability analysis, exploitation methodology and remediation.

1. Executive Summary

This vulnerability exists in a filtered archive access system with high-security mode enabled. The Web Application Firewall (WAF) blocks standard path traversal attempts, but can be fully bypassed by submitting a fully URL-encoded path traversal string, which the WAF fails to decode before inspection.

2. Vulnerability Description

The WAF performs literal string matching on incoming file paths to detect and block traversal sequences like ../. However, if the entire traversal string is URL-encoded before submission, the WAF does not decode the request, while the backend file handler does decode and process the path correctly, bypassing the WAF rule entirely.

3. Exploitation Methodology

Step 1: Test standard path traversal sequences to confirm the WAF is active and blocking direct requests. Step 2: URL-encode every character in the path traversal string, including slashes, dots, and filename characters. Step 3: Submit the fully encoded path. The WAF does not recognize the encoded sequence as malicious, while the backend decodes it and reads the restricted file successfully.

4. Impact

This WAF bypass allows attackers to read any arbitrary file on the server, bypassing all high-security path filtering rules. This can lead to full disclosure of configuration files, credentials, and sensitive system data.

5. Remediation Recommendations

Decode and normalize all incoming file paths before performing WAF inspection. Implement path canonicalization to resolve all relative traversal sequences before comparing against allowed paths. Enforce a strict base directory chroot for all file read operations, so any traversal attempt resolves to a non-existent path outside the allowed root.